

BÁO CÁO ĐÁNH GIÁ DỰ ÁN SMARTNOTE

Phân tích mã nguồn, yêu cầu, kiến trúc, dữ liệu, bảo mật, kiểm thử và triển khai

Thuộc tính	Nội dung
Dự án	SmartNote — ứng dụng ghi chú Flutter offline-first
Repository	github.com/theihoz/smartnote
Nhánh đánh giá	feature/smartnote-app
Phiên bản ứng dụng	1.0.0+1
Ngày đánh giá	15/08/2026
Phạm vi	Mã nguồn cục bộ và cấu hình Supabase production (chỉ đọc)

Tài liệu được lập theo kế hoạch phân tích 28 mục do người dùng cung cấp. Các kết luận phân biệt rõ chức năng đã triển khai, khoảng trống và đề xuất.

Mục lục

Kết luận chính	3
2.1 Bài toán và mục tiêu	3
2.2 Tính năng hiện có	4
Luồng khởi động	4
5.1 Functional Requirements	6
5.2 Non-functional Requirements	6
6.1 Danh sách use case	7
6.2 Đặc tả UC-01 — Tạo hoặc chỉnh sửa ghi chú	7
6.3 Đặc tả UC-08 — Đồng bộ cloud.....	7
6.4 Class/component model	8
7.1 Data dictionary rút gọn	9
7.2 Đánh giá thiết kế dữ liệu	9
Data flow	10
Quy ước lỗi cần chuẩn hóa	11
Cơ chế tốt đang có	11
Test cases đại diện	12
Deployment guide tối thiểu	13
Điểm mạnh.....	13
Điểm yếu	13
Short-term — 1 đến 2 tuần.....	14
Medium-term — 1 đến 2 tháng.....	14
Long-term — 3 đến 6 tháng.....	14

Mở tài liệu trong Microsoft Word và chọn Update Table để cập nhật số trang.

1. Tóm tắt điều hành

SmartNote là ứng dụng ghi chú Android viết bằng Flutter, ưu tiên hoạt động ngoại tuyến với SQLite và bổ sung đồng bộ tài khoản qua Supabase. Dự án đã có nền tảng chức năng tốt cho một sản phẩm cá nhân: ghi chú văn bản/checklist, tìm kiếm, nhãn, nhắc việc, thùng rác, khóa PIN, xuất PDF/Markdown, song ngữ và giao diện sáng/tối.

Hạng mục	Đánh giá	Nhận định
Chức năng	Khá	Phần lớn luồng người dùng đã hiện diện; đồng bộ thủ công và lịch sử phiên bản chưa hoàn chỉnh.
Kiến trúc	Khá	Tách feature/domain/data/presentation hợp lý; client là modular monolith.
Dữ liệu	Khá	SQLite quan hệ tốt; Supabase có RLS, nhưng phạm vi sync hẹp hơn schema.
Bảo mật	Trung bình	RLS và quản lý khóa đúng hướng; PIN chỉ bảo vệ UI, chưa mã hóa dữ liệu cục bộ.
Kiểm thử	Trung bình–Khá	Có 11 tệp test cục bộ; test và migration hiện không được theo dõi trong Git.
Triển khai	Cần cải thiện	Chưa có CI/CD, giám sát và release signing production.

Kết luận chính

- Phù hợp làm đồ án/sản phẩm MVP và có thể phát triển thành ứng dụng cá nhân đa thiết bị.
- Rủi ro ưu tiên cao nhất: release Android đang dùng khóa debug; test và migration bị loại khỏi repository; nút đồng bộ chưa thực thi hành động.
- Supabase production đang ACTIVE_HEALTHY tại khu vực Singapore; 3 bảng public đều bật RLS. Advisor vẫn cảnh báo chính sách có thể áp dụng cho anonymous và tính năng leaked-password protection đang tắt.

2. Tổng quan dự án

2.1 Bài toán và mục tiêu

Dự án giải quyết nhu cầu ghi chép nhanh, tổ chức công việc và truy cập dữ liệu khi không có mạng. Mục tiêu kỹ thuật là phản hồi nhanh nhờ dữ liệu cục bộ, sau đó đồng bộ có kiểm soát lên cloud khi người dùng đăng nhập.

Nội dung	Kết quả phân tích
Người dùng mục tiêu	Cá nhân, sinh viên, nhân viên văn phòng cần ghi chú/nhắc việc trên Android.

Phạm vi	Ứng dụng Android; không có web admin, backend tùy chỉnh hoặc iOS trong repository.
Trạng thái	Đang phát triển tích cực; nhiều commit tính năng/sửa lỗi gần đây.
License	Không tìm thấy tệp LICENSE — quyền sử dụng/phân phối chưa được tuyên bố rõ.
Quản trị	Không có vai trò Administrator trong luồng nghiệp vụ hiện tại.

2.2 Tính năng hiện có

- Ghi chú văn bản và checklist; ảnh từ camera/thư viện; yêu thích, nhấn, tìm kiếm và lọc.
- Tự động lưu bản nháp; lưu tối đa 20 snapshot phiên bản cho mỗi ghi chú.
- Nhắc việc bằng thông báo cục bộ; thùng rác soft-delete 30 ngày.
- Khóa ghi chú bằng PIN chung 4–6 số; xuất/chia sẻ PDF hoặc Markdown.
- Đăng ký/đăng nhập email–mật khẩu; đồng bộ ghi chú qua Supabase.
- Tiếng Việt/Anh và light/dark/system được lưu bằng SharedPreferences.

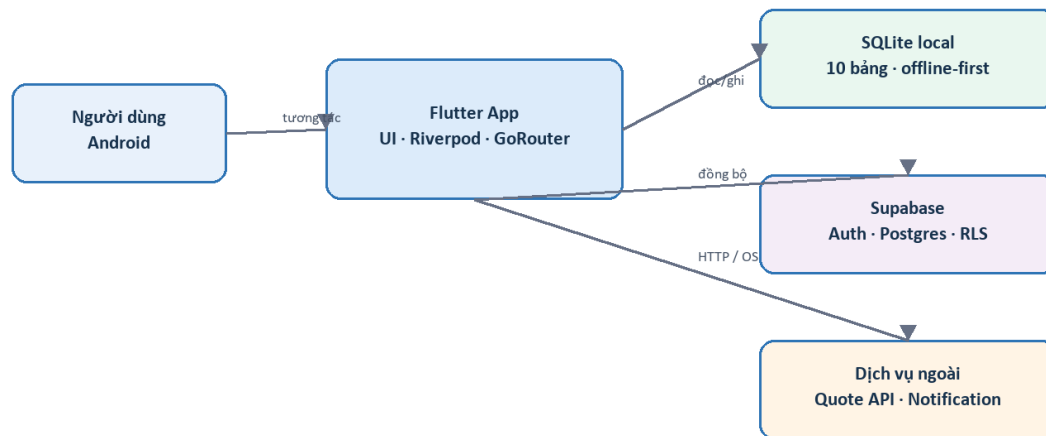
3. Repository và luồng chạy

Khu vực	Vai trò
lib/main.dart	Entry point; khởi tạo SharedPreferences, SQLite, notification, Supabase tùy cấu hình và Riverpod.
lib/app	Theme, routing, provider và shell điều hướng responsive.
lib/features	Các feature auth, notes, reminders, security, export, sync, settings, inspiration.
lib/l10n	ARB/generated localization và helper featureText.
android	Manifest, Gradle và cấu hình build Android.
test	11 tệp test cục bộ; hiện bị .gitignore loại khỏi repository.
supabase/migrations	Migration cloud cục bộ; hiện bị .gitignore loại khỏi repository.
download_site	Trang tải APK cục bộ; hiện không theo dõi Git.

Luồng khởi động

Flutter binding → tải cài đặt → mở SQLite v5 → khởi tạo repository/scheduler → thử cấu hình Supabase từ --dart-define → nếu có session thì xử lý outbox và kéo dữ liệu cloud → dựng MaterialApp.router. Nếu cloud lỗi, ứng dụng vẫn tiếp tục ở chế độ local; tuy nhiên lỗi bị nuốt và không có telemetry.

Kiến trúc tổng thể SmartNote



Hình 1 — Kiến trúc tổng thể và các hệ thống liên quan

4. Technology stack

Thành phần	Công nghệ	Phiên bản	Vai trò	Nhận xét
Client	Flutter / Dart	SDK Dart ^3.12.2	UI đa nền tảng	Material 3; repository hiện chỉ có Android
State	flutter_riverpod	2.6.1	Quản lý trạng thái	Provider override hỗ trợ kiểm thử
Routing	go_router	17.3.0	Điều hướng	Route rõ theo feature
Local DB	SQLite / sqflite	2.4.3	Offline-first	Transaction + FK; có một index tạo mới thiếu
Cloud	Supabase Flutter	2.16.0	Auth/Postgres sync	Dùng publishable key qua dart-define
HTTP	http	1.6.0	Quote API	Không có backend REST riêng
Export	pdf / share_plus	3.13.0 / 13.3.0	PDF/Markdown	Xử lý trên thiết bị
Notification	flutter_local_notifications	22.2.0	Nhắc việc	Có timezone
Settings	shared_preferences	2.5.5	Theme/locale/PIN	Không phù hợp lưu bí mật mạnh
CI/CD	Không có	—	—	Khoảng trống triển khai

5. Actor và yêu cầu

Actor	Quyền hạn	Dữ liệu truy cập
Guest / Local user	Dùng toàn bộ chức năng cục bộ, không đồng bộ cloud.	SQLite và file ảnh trên thiết bị.
Authenticated user	Như local user; đăng nhập và đồng bộ ghi chú của chính mình.	Bản ghi có user_id = auth.uid() trên Supabase.

Android OS	Cấp quyền camera/thông báo; kích hoạt notification.	Quyền thiết bị trong phạm vi ứng dụng.
Supabase	Xác thực và lưu dữ liệu cloud theo RLS.	notes, note_reminders, note_versions.

5.1 Functional Requirements

ID	Chức năng	Actor	Mô tả	Ưu tiên
FR-001	Tạo/sửa ghi chú	User	Lưu text hoặc checklist, nhãn, ảnh, màu	High
FR-002	Tìm kiếm/lọc	User	Tìm theo nội dung, yêu thích, nhãn và sắp xếp	High
FR-003	Hoàn tác	User	Hoàn tác tạo/sửa/xóa trong 5 giây	High
FR-004	Bản nháp	User	Tự động lưu nội dung đang soạn	High
FR-005	Phiên bản	User	Lưu tối đa 20 snapshot mỗi ghi chú	Medium
FR-006	Nhắc việc	User	Lập lịch và thông báo cục bộ	High
FR-007	Thùng rác	User	Soft-delete, khôi phục trong 30 ngày	High
FR-008	Khóa ghi chú	User	Bảo vệ truy cập UI bằng PIN	High
FR-009	Xuất/chia sẻ	User	Gộp nhiều ghi chú thành PDF/Markdown	Medium
FR-010	Tài khoản	User	Đăng ký/đăng nhập email–mật khẩu	High
FR-011	Đồng bộ	Auth user	Push outbox, pull bản cập nhật theo thời gian	High
FR-012	Giao diện	User	VI/EN và light/dark/system có lưu	Medium

5.2 Non-functional Requirements

ID	Nhóm	Tiêu chí
NFR-001	Performance	Mở/list dữ liệu cục bộ phản hồi nhanh; cần đo p95.
NFR-002	Reliability	Mất cloud không làm mất khả năng ghi chú local.
NFR-003	Security	Mọi bằng exposed bật RLS; không nhúng service-role key.
NFR-004	Privacy	Dữ liệu local nhạy cảm cần mã hóa at-rest trong bản production.
NFR-005	Availability	Cloud phụ thuộc Supabase; local vẫn hoạt động offline.
NFR-006	Maintainability	Feature modules, lint sạch, test/migration phải theo dõi Git.
NFR-007	Usability	Luồng chính tối đa ít thao tác, phản hồi lỗi rõ ràng.
NFR-008	Accessibility	Semantics, tương phản, kích thước chạm và text scaling phải được kiểm tra.
NFR-009	Compatibility	Android minSdk 24; kiểm thử nhiều kích cỡ và phiên bản OS.
NFR-010	Scalability	Sync phân trang/batch, retry backoff khi dữ liệu tăng.

6. Phân tích nghiệp vụ và UML rút gọn

6.1 Danh sách use case

UC-01 Quản lý ghi chú; UC-02 Tìm kiếm/lọc; UC-03 Lập nhắc việc; UC-04 Xóa/khôi phục; UC-05 Khóa/mở khóa; UC-06 Xuất/chia sẻ; UC-07 Đăng ký/đăng nhập; UC-08 Đồng bộ cloud; UC-09 Đổi ngôn ngữ/giao diện.

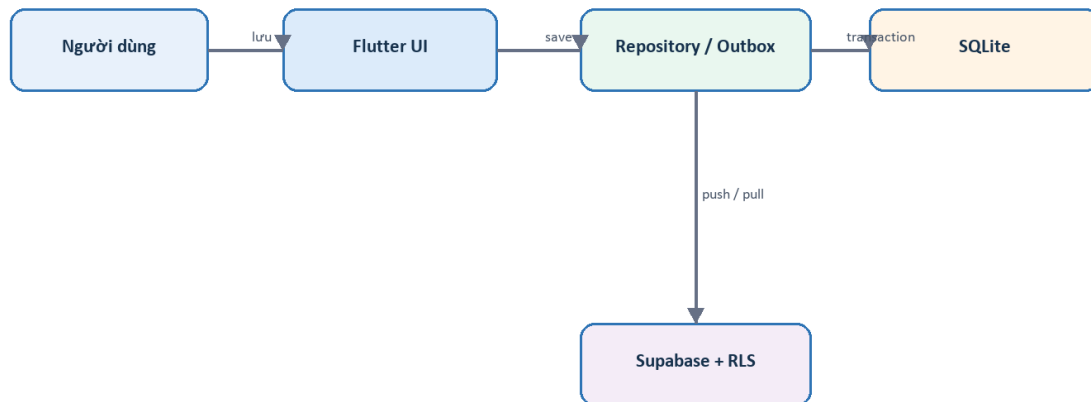
6.2 Đặc tả UC-01 — Tạo hoặc chỉnh sửa ghi chú

Thuộc tính	Nội dung
Actor	Local user / Authenticated user
Tiền điều kiện	Ứng dụng đã mở; SQLite khả dụng.
Trigger	Người dùng chọn tạo mới hoặc mở ghi chú.
Luồng chính	Nhập dữ liệu → validator kiểm tra → repository lưu transaction → tạo snapshot/outbox → tải lại danh sách → hiển thị Snackbar hoàn tác.
Luồng thay thế	Nội dung đang soạn được lưu draft; có thể thêm checklist, ảnh, nhãn, reminder.
Ngoại lệ	Validation thất bại hoặc SQLite lỗi: giữ màn hình và hiển thị lỗi.
Hậu điều kiện	Ghi chú local nhất quán; sẵn sàng sync khi có tài khoản.

6.3 Đặc tả UC-08 — Đồng bộ cloud

Thuộc tính	Nội dung
Actor	Authenticated user
Tiền điều kiện	Supabase được cấu hình; có session.
Trigger hiện tại	Khởi động ứng dụng khi đã có session.
Luồng chính	Đọc outbox → upsert/soft-delete cloud → kéo notes mới hơn last_synced_at → áp dụng nếu remote.updated_at mới hơn local.
Ngoại lệ	Tăng attempts; giữ outbox. Không có backoff/max retry/dead-letter.
Khoảng trống	Đăng nhập không kích hoạt sync ngay; nút Sync trong Settings chưa có callback thực. Reminder/version chưa được sync.

Luồng đồng bộ ghi chú



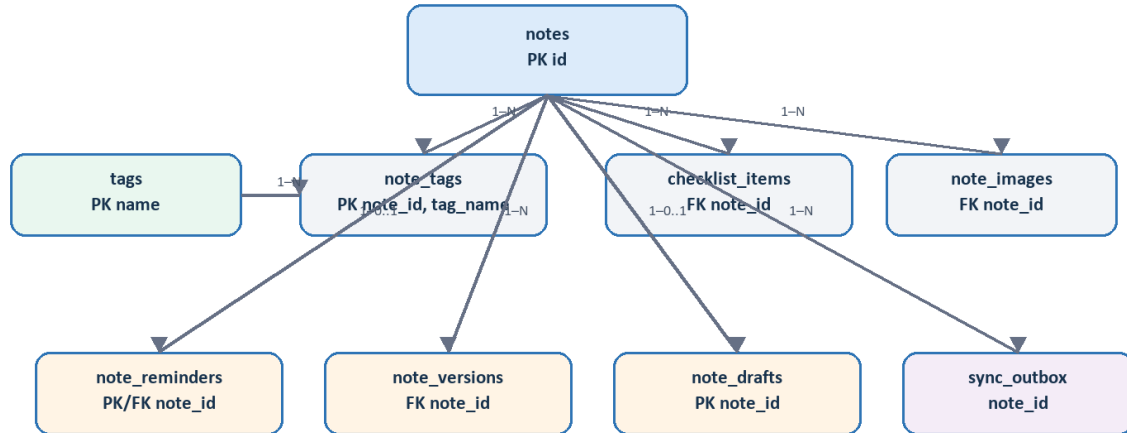
Hình 2 — Sequence rút gọn của luồng lưu và đồng bộ

6.4 Class/component model

Presentation screens phụ thuộc Riverpod providers; NotesController điều phối NoteRepository; SqliteNoteRepository chịu trách nhiệm transaction/hydration/outbox; OutboxSyncService phối hợp local repository với CloudNoteStore; SupabaseCloudNoteStore gọi Data API. Các service độc lập xử lý draft, reminder, PIN và export. Đây là phân tách trách nhiệm hợp lý, chưa cần tách thành nhiều package.

7. Cơ sở dữ liệu

ERD rút gọn — cơ sở dữ liệu cục bộ



Hình 3 — ERD rút gọn của SQLite (sync_state không thể hiện)

7.1 Data dictionary rút gọn

Bảng	Cột chính	Ràng buộc	Vai trò
notes	id; title; body; kind; is_favorite; color_key; deleted_at; is_locked; timestamps	PK id	Thực thể chính
tags	name	PK, NOCASE	Danh mục nhãn
note_tags	note_id; tag_name; position	PK kép; 2 FK	Quan hệ N–N
checklist_items	id; note_id; text; is_done; position	PK; FK cascade	Dòng checklist
note_images	note_id; path; position	PK kép; FK cascade	Đường dẫn ảnh local
note_reminders	note_id; schedule; repeat...	PK/FK cascade	Cấu hình nhắc
note_versions	id; note_id; snapshot; created_at	PK; FK cascade; index	Snapshot JSON
note_drafts	note_id; title; body; updated_at	PK	Bản nháp
sync_outbox	id; note_id; operation; attempts	PK auto	Hàng đợi đồng bộ
sync_state	key; last_synced_at	PK key	Mốc pull cloud

7.2 Đánh giá thiết kế dữ liệu

- Ưu điểm: FK được bật; child rows cascade; transaction khi lưu; version giới hạn 20; soft-delete hỗ trợ khôi phục.
- Lỗi schema: notes_deleted_at_idx chỉ được tạo trong đường upgrade từ v1, không được tạo khi cài mới trực tiếp schema v5.
- Hiệu năng: hydrate mỗi note truy vấn riêng tags/checklist/images, tạo mẫu N+1; nên batch theo danh sách id khi dữ liệu tăng.

- Cloud dùng JSONB cho tags/images/checklist để đơn giản sync. Hợp lý cho MVP nhưng giảm khả năng truy vấn quan hệ trên server.
- Cloud production có 3 bảng: notes, note_reminders, note_versions; tất cả RLS enabled và hiện chưa có dữ liệu.

8. Kiến trúc hệ thống và C4

Mức	Mô tả
C4 L1 — Context	Người dùng tương tác SmartNote; ứng dụng dùng Android OS, Supabase và Quote API.
C4 L2 — Container	Flutter Android app + SQLite local + Supabase Auth/Postgres; không có backend riêng.
C4 L3 — Component	Presentation → Riverpod/controller → repository/service → SQLite/Supabase/plugin.
Deployment	APK trên thiết bị; DB local trong sandbox app; cloud tại ap-southeast-1.

Data flow

Dữ liệu người dùng được ghi vào SQLite trước. Repository cập nhật các bảng con và outbox trong transaction. Đồng bộ đẩy dữ liệu sang Supabase bằng JWT session; RLS lọc theo user_id. Ảnh hiện chỉ lưu đường dẫn local, vì vậy không thể xuất hiện trên thiết bị thứ hai nếu không bổ sung Storage/upload mapping.

9. API và dịch vụ ngoài

SmartNote không định nghĩa REST backend tùy chỉnh. “API” của hệ thống là Supabase Auth/Data API do SDK Dart gọi và một Quote API công khai. Vì vậy không có các endpoint /api/... do dự án tự sở hữu để tài liệu hóa.

Tác vụ	Giao thức/đích	Auth	Request chính	Kết quả/lỗi
Đăng ký	Supabase Auth signUp	Publishable key	email, password	User/session hoặc AuthException
Đăng nhập	Supabase Auth signInWithPassword	Publishable key	email, password	Session/JWT hoặc AuthException
Đẩy note	Data API: upsert notes	Bearer JWT	Bản ghi note + user_id	Row upsert; RLS bảo vệ
Xóa mềm	Data API: update notes	Bearer JWT	deleted_at, updated_at	Row update
Kéo note	Data API: select notes	Bearer JWT	updated_at > checkpoint	Danh sách JSON
Quote	HTTP GET dịch vụ ngoài	Không	Không/locale tùy repository	Quote hoặc fallback/error

Quy ước lỗi cần chuẩn hóa

UI hiện thường hiển thị chuỗi exception trực tiếp. Nên ánh xạ lỗi thành mã nội bộ (AUTH_INVALID_CREDENTIALS, NETWORK_UNAVAILABLE, SYNC_CONFLICT, STORAGE_FAILURE), thông điệp VI/EN thân thiện và log kỹ thuật riêng; không hiển thị chi tiết nhạy cảm từ backend.

10. Phân tích bảo mật

Mức	Phát hiện	Ảnh hưởng	Khuyến nghị
High	Release Android dùng debug signing key	APK production không có danh tính phát hành an toàn.	Thiết lập keystore release qua biến bí mật; chặn release nếu thiếu.
High	test và Supabase migrations bị ignore	Không tái lập được kiểm thử/schema; tăng rủi ro drift và mất lịch sử.	Theo dõi lại hai thư mục, chỉ ignore artefact sinh ra/secrets.
Medium	Advisor: policy có thể áp dụng anonymous	Anonymous sign-in có thể làm thay đổi mô hình tin cậy dù predicate sở hữu vẫn tồn tại.	Tắt anonymous nếu không dùng; policy TO authenticated + auth.uid ownership.
Medium	Leaked password protection tắt	Cho phép mật khẩu đã lộ.	Bật trong Supabase Auth và quy định độ mạnh mật khẩu.
Medium	PIN hash trong SharedPreferences	Khóa UI, không mã hóa nội dung/DB; thiết bị bị compromise có thể đọc dữ liệu.	Dùng Android Keystore/biometric và SQLCipher nếu dữ liệu nhạy cảm.
Medium	Ảnh chỉ là đường dẫn local	Có thể rò dữ liệu qua backup/quyền file tùy vị trí.	Lưu app-private; kiểm MIME/kích thước; dùng Storage RLS khi sync.
Low	Exception cloud bị nuốt/hiển thị trực tiếp	Thiếu audit; có thể lộ chi tiết kỹ thuật.	Structured logging + thông điệp lỗi chuẩn hóa.
Info	SQL injection/XSS/CSRF	sqlite dùng tham số; app native không có DOM/cookie web.	Duy trì validation; đánh giá lại nếu thêm WebView/web client.

Cơ chế tốt đang có

- Không nhúng service-role key; cấu hình cloud qua dart-define và publishable key.
- RLS bật trên cả 3 bảng public; FK user_id tham chiếu auth.users.
- PIN dùng salt ngẫu nhiên, HMAC-SHA256 120.000 vòng, so sánh constant-time và khóa 30 giây sau 5 lần sai.
- Input email/password/PIN/note được kiểm tra; thao tác SQLite dùng API tham số hóa.

11. Kiểm thử

Repository cục bộ có 11 tệp test bao phủ domain, NotesController, SQLite repositories, draft, reminder, PIN, export, quote, sync và widget app. Lần chạy xác nhận trước trong quá trình phát triển ghi nhận 48 test pass, flutter analyze không có lỗi và debug APK build thành công. Trong lần lập báo cáo này, lệnh kiểm thử không kết thúc và không phát sinh output trong thời gian chờ, nên không coi đó là bằng chứng chạy mới; cần kiểm tra môi trường Flutter/process lock.

Loại	Hiện trạng	Khoảng trống
------	------------	--------------

Unit	Có	Cần giữ trong Git và CI.
Widget/UI	Có smartnote_app_test	Chưa có regression ảnh/accessibility.
Integration	Chưa thấy test thật trong integration_test	Thêm luồng DB + notification + auth mock.
API/live	Không	Không nên phụ thuộc production; dùng project test.
Security	Một số PIN/RLS gián tiếp	Thiếu kiểm tra policy và secret scanning.
Performance	Không	Đo cold start, list 1k notes, sync batch.
UAT	Không	Lập checklist thiết bị thật VI/EN, light/dark.

Test cases đại diện

ID	Feature	Input	Expected	Actual	Status
TC-001	Tạo note hợp lệ	Title/body hợp lệ	Lưu, xuất hiện danh sách	Đã có test	Pass trước
TC-002	Undo xóa	Xóa rồi undo <5s	Note khôi phục	Đã có test	Pass trước
TC-003	Draft	Thoát editor sau nhập	Mở lại còn draft	Đã có test	Pass trước
TC-004	PIN lockout	Sai PIN 5 lần	Khóa 30 giây	Đã có test	Pass trước
TC-005	Sync conflict	Remote mới hơn local	Remote thắng	Đã có test	Pass trước
TC-006	Theme persistence	Chọn dark, khởi động lại	Vẫn dark	Có settings test	Pass trước
TC-007	Reminder OS	Lịch tương lai	Notification đúng giờ	Chưa chạy thiết bị	Pending
TC-008	RLS isolation	User A đọc note B	0 row/denied	Chưa tự động hóa	Pending

12. Deployment

Hạng mục	Hiện trạng	Đánh giá
Development	Flutter SDK; pubspec/lockfile; Android minSdk 24	Có thể dựng local khi cấu hình SDK.
Environment	SUPABASE_URL và SUPABASE_PUBLISHABLE_KEY qua --dart-define	Đúng hướng; cần tài liệu hóa template không chứa secret.
Build	flutter build apk	Release hiện ký bằng debug key — không dùng production.
Database migration	3 migration đã áp dụng trên Supabase production	Tệp migration local bị ignore, không tái lập được.
Hosting	Supabase ap-southeast-1; trang tải/APK từng được mô tả	Không có pipeline phát hành tự động.
CI/CD	Không có	Cần GitHub Actions: format/analyze/test/build/secret scan.
Backup/monitoring	Không cấu hình trong repo	Cần PITR/backup theo gói, crash reporting và sync metrics.
HTTPS	Supabase/Quote API qua HTTPS	Được cung cấp bởi dịch vụ; không có reverse proxy.

Deployment guide tối thiểu

- Cài Flutter tương thích và Android SDK; chạy flutter pub get.
- Cấp SUPABASE_URL và publishable key bằng --dart-define; tuyệt đối không dùng service-role key.
- Chạy format, analyze và test; kiểm tra migration production khớp repository.
- Tạo keystore release, lưu secrets ngoài Git; build appbundle/APK release.
- Kiểm thử trên thiết bị Android thật: permission, notification, offline/sync, VI/EN và light/dark.
- Phát hành qua kênh kiểm thử; theo dõi crash, auth và sync trước production.

13. Chất lượng mã và kiến trúc

Tiêu chí	Nhận xét	Mức
Cấu trúc	Feature-based, domain/data/presentation rõ	Tốt
Naming	Tên lớp/tệp nhất quán, dễ truy vết	Tốt
Separation of concerns	Repository/service tách khỏi UI; controller tương đối gọn	Tốt
Error handling	Có fallback offline nhưng nuốt lỗi cloud và UI đôi khi lộ exception	Cần cải thiện
Logging/monitoring	Hầu như chưa có	Yếu
Testing	Phạm vi unit/widget tốt cho MVP nhưng không được commit	Trung bình
Documentation	README có hướng dẫn cơ bản; thiếu license/API/deployment chuẩn	Trung bình
Dependencies	Phiên bản pin trong pubspec.lock; bộ thư viện phù hợp	Khá
Performance	Có N+1 hydration và sync chưa batch/backoff	Cần đo

Điểm mạnh

- Offline-first thực tế, transaction và outbox giảm nguy cơ mất dữ liệu khi mạng gián đoạn.
- UI/UX đã có nền tảng Material 3, responsive, song ngữ và lưu theme.
- RLS theo người dùng, xác thực chuẩn Supabase và không đưa khóa đặc quyền vào client.

Điểm yếu

- Cloud schema và client sync chưa đồng nhất: reminder/version tồn tại nhưng sync service chỉ xử lý notes.
- Sync chủ yếu lúc khởi động; nút Sync chưa hoạt động và đăng nhập thành công chưa kéo dữ liệu ngay.
- History snapshot chưa có màn hình xem/khôi phục; ảnh không đồng bộ đa thiết bị.

14. Technical debt và Improvement plan

ID	Vấn đề	Mức	Ảnh hưởng	Đề xuất
TD-01	Release debug-signed	High	Không phát hành an toàn	Release keystore + CI guard
TD-02	Test/migration bị ignore	High	Mất khả năng tái lập	Đưa lại vào Git
TD-03	Nút Sync rỗng	High	Người dùng hiểu sai trạng thái	Gọi sync service + trạng thái tiến trình
TD-04	Reminder/version không sync	Medium	Dữ liệu khác nhau giữa thiết bị	Mở rộng outbox hoặc ghi rõ local-only
TD-05	N+1 SQLite hydration	Medium	Chậm khi nhiều notes	Batch query theo note_id
TD-06	LWW dựa timestamp	Medium	Xung đột/clock skew	Server timestamp + conflict metadata
TD-07	PIN/DB chưa mã hóa	Medium	Rò dữ liệu khi thiết bị compromise	Keystore/biometric + encrypted DB
TD-08	Thiếu observability	Medium	Khó chẩn đoán lỗi production	Crash/log/sync metrics
TD-09	Hai cơ chế localization	Low	Dễ lệch bản dịch	Quy về ARB/generated l10n
TD-10	Index deleted_at thiếu khi cài mới	Low	Query trash có thể chậm	Tạo index trong _createSchema

Short-term — 1 đến 2 tuần

- Sửa release signing; đưa test và migrations trở lại Git; thêm CI tối thiểu.
- Nối nút Sync và sync sau đăng nhập; hiển thị trạng thái/thời điểm sync gần nhất.
- Sửa index fresh-install; chuẩn hóa lỗi; bật leaked-password protection và rà policy anonymous.

Medium-term — 1 đến 2 tháng

- Đồng bộ reminder/version hoặc tuyên bố rõ local-only; bổ sung Storage cho ảnh.
- Tối ưu batch hydration và sync retry/backoff; thêm integration/UAT/accessibility tests.
- Màn hình lịch sử phiên bản và khôi phục; telemetry không chứa nội dung ghi chú.

Long-term — 3 đến 6 tháng

- Mã hóa dữ liệu local, biometric/Keystore và threat model đầy đủ.
- Đồng bộ xung đột rõ ràng hơn, phân trang/batch và hỗ trợ nhiều thiết bị.
- Quy trình phát hành production, backup/khôi phục và SLA/monitoring.

15. Roadmap đề xuất

Giai đoạn	Mục tiêu	Điều kiện hoàn thành
Phase 1 — Stabilize	Signing, Git hygiene, CI, Sync UX, security advisor	Build release có chữ ký; CI xanh; migration/test tái

		lập được.
Phase 2 — Complete	Version UI, cloud parity, ảnh, integration test	Dữ liệu nhất quán hai thiết bị; test luồng chính tự động.
Phase 3 — Harden & Scale	Encryption, conflict model, monitoring, performance	Đạt ngưỡng bảo mật/hiệu năng đã định lượng.

16. Checklist và trả lời cuối cùng

Trạng thái	Hạng mục
Hoàn thành	Hiểu mục tiêu, phạm vi và người dùng
Hoàn thành	Phân tích repository, stack và luồng chạy
Hoàn thành	Xác định actor, FR và NFR
Hoàn thành	Lập use case/sequence/class model rút gọn
Hoàn thành	Phân tích SQLite, Supabase, ERD và data dictionary
Hoàn thành	Phân tích architecture/C4/data flow
Hoàn thành	Phân tích API, security, testing và deployment
Hoàn thành	Đánh giá code/architecture, technical debt và roadmap

Câu hỏi	Trả lời
1. Dự án giải quyết gì?	Ghi chú và nhắc việc cá nhân, ưu tiên offline và có đồng bộ.
2. Ai sử dụng?	Người dùng local và người dùng đã xác thực; không có admin app.
3. Chức năng?	CRUD note/checklist, search/tag, draft/version, reminder, trash, lock, export, sync, VI/EN/theme.
4. Source tổ chức?	Feature-based Flutter, phân lớp presentation/application/domain/data.
5. Công nghệ?	Flutter/Dart, Riverpod, GoRouter, SQLite, Supabase, notification/PDF plugins.
6. Database?	10 bảng SQLite quan hệ; 3 bảng Supabase JSONB + RLS.
7. Thành phần giao tiếp?	UI → controller/provider → repository/service → SQLite/Supabase/OS.
8. API?	Supabase Auth/Data API và Quote API; không có REST backend riêng.
9. Bảo mật?	RLS, JWT, publishable key, PIN hashing; còn thiếu encryption và hardening production.
10. Kiểm thử?	11 tệp unit/widget local; thiếu CI, integration, security/performance/UAT.
11. Triển khai?	APK Android + Supabase Singapore; thiếu release signing và CI/CD.
12. Điểm mạnh/yếu?	Mạnh offline-first/modular; yếu ở cloud parity, observability và release process.
13. Cần cải thiện?	Git hygiene, sync UX, signing, security advisor, test automation, performance.
14. Hướng phát triển?	Hoàn thiện đa thiết bị, ảnh cloud, history UI, encryption và monitoring.

17. Phạm vi và nguồn bằng chứng

Đánh giá dựa trên mã nguồn tại workspace, README/pubspec, lịch sử Git, schema SQLite, test cục bộ và truy vấn chỉ đọc Supabase project ijfiountpfumysfbwrqh ngày lập báo cáo. Không thực hiện penetration test, kiểm thử tải, kiểm thử thiết bị thật hoặc thay đổi dữ liệu/schema production. Issue/PR trên GitHub không được dùng làm bằng chứng vì không có dữ liệu cục bộ đáng tin cậy trong phạm vi đánh giá.

Mức độ ưu tiên là đánh giá kỹ thuật tại thời điểm hiện tại, không thay thế kiểm toán bảo mật độc lập hoặc tiêu chuẩn phát hành của cửa hàng ứng dụng.